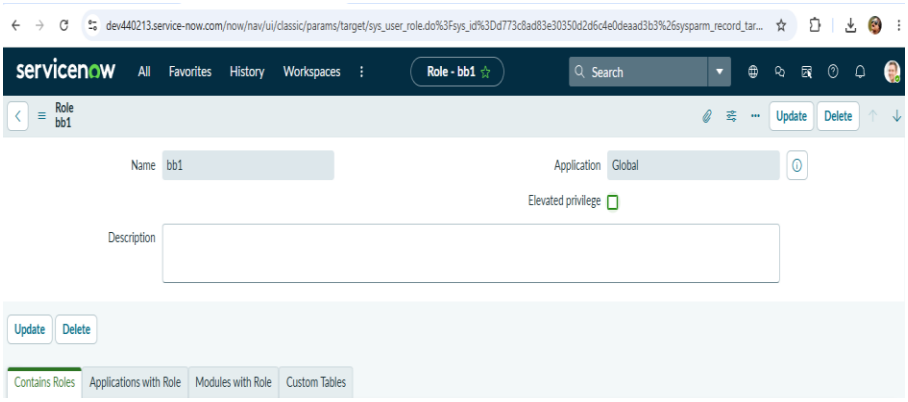
SCRIPT-CONTROLLED ACL Restrict Record Access Based on Field Value (ServiceNow)

Phase 6- Project testing

6.1 Testing Approach

Because ACL behaviour depends entirely on who is logged in, the project was tested using ServiceNow's Impersonate User feature rather than automated unit tests. Each test case impersonates a specific user/role combination, opens the Institution Details list, and records what is visible and which actions (New, Edit, Delete) are available.

6.2 Test Procedure



1. Impersonate the EEE user (role bb1 only) and open the Student Records list.
2. Copy the table name u_institution_details_list.LIST and paste it into the navigator's All menu to load the list directly.
3. Observe which records are visible and which actions are available.
4. Impersonate Admin and open the same Student Records list for comparison.

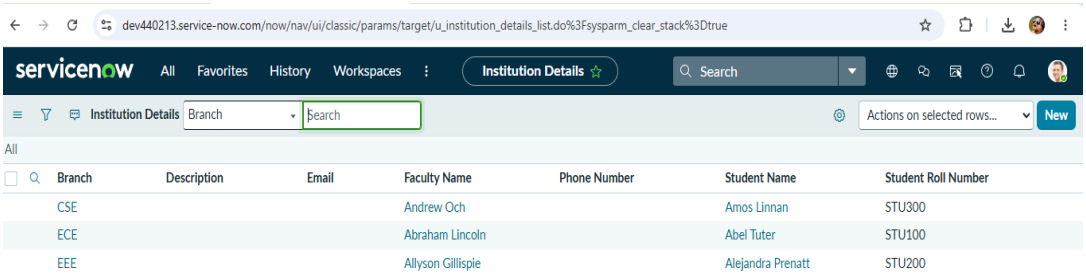
6.3 Test Cases and Results

Test Case	User / Role	Expected Result	Actual Result
TC-1	User with bb1 only	Can view only EEE-branch records; no New button	Pass — only EEE records (Guna Sai, Prashanth Reddy) shown

Test Case	User / Role	Expected Result	Actual Result
TC-2	User with no role	Cannot view any record	Pass — list displays “No records to display”
TC-3	User with bb1 + bb2	Can view EEE records and see a New button to create records	Pass — New button appeared alongside the EEE records
TC-4	User with bb1 + bb2 + bb3	Can view, create and edit (inline) EEE records	Pass — Description field became editable; “ACL Is Executed” saved successfully
TC-5	User with bb1 + bb2 + bb3 + bb4	Can view, create, edit and delete EEE records	Pass — record deleted successfully after confirmation
TC-6	Administrator	Can view and manage all records regardless of branch	Pass — ECE, EEE and CSE records all visible and editable

6.4 Detailed Observations

6.4.1 Role-Restricted Read



With only the bb1 role assigned, the impersonated EEE user's Institution Details list showed exactly the records whose Branch equals EEE — for example, roll numbers INS0001007 and INS0001004 — while ECE and CSE records such as INS0001006 and INS0001008 were completely absent from the list, confirming that the data condition and script are both being evaluated together rather than either one alone.

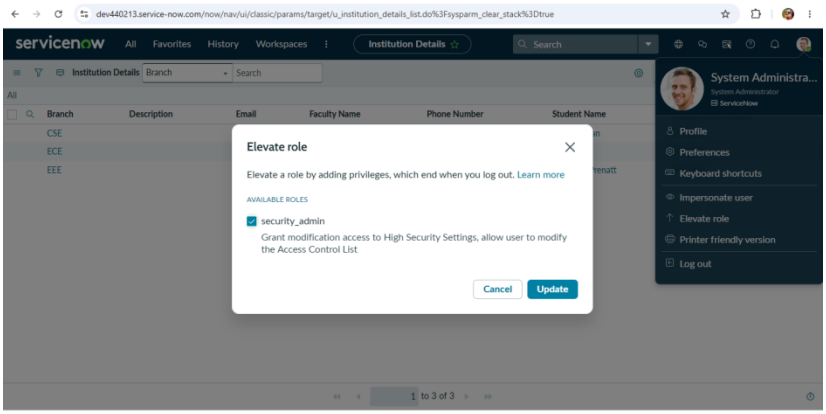
6.4.2 No-Role Access

When the same user's roles were removed, the list rendered with zero records and the standard “No records to display” placeholder, confirming the ACL's deny-by-default behaviour rather than silently showing partial data.

6.4.3 Progressive Privilege

Adding bb2 introduced the New button, confirming the Create ACL was independently evaluated; adding bb3 made the Description field editable inline on the EEE records, confirming the Write ACL; and adding bb4 enabled the Delete action from the “Actions on selected rows…” menu, which after a confirmation dialog removed the selected record.

6.4.4 Administrator Over ride



The impersonated System Administrator, without holding bb1–bb4 at all, could still see, create, edit and delete every record across all three branches (ECE, EEE, CSE), confirming that the gs.has Role('admin') check in the Read ACL script — and the platform's default admin-overrides-ACL behaviour on the other three ACLs — functioned as designed.

6.5 Defects Found and Resolved

Issue	Cause	Resolution
EEE user initially saw no records even with bb1 assigned	Role was created but not yet assigned to the user record	Explicitly added the bb1 role under the user's Roles related list
ACL appeared to have no effect	Advanced flag was left unchecked, so the script field was ignored	Enabled the Advanced checkbox on the Read ACL before adding the script

6.6 Non-Functional and Negative Testing

- Performance — the advanced script performs only two lightweight gs.hasRole() calls per record evaluation, so no noticeable delay was observed when loading a list of sample records.
- Negative test — a user holding only bb2, bb3 or bb4 (but not bb1) was still unable to view any EEE record, confirming that create/write/delete privileges alone do not bypass the Read ACL's role and data-condition checks.
- Negative test — attempting to load a record directly by its table/sys_id URL as a no-role user still returned no data, confirming the ACL is enforced at the platform level and not only on the list view.
- Regression check — after adding the Read ACL, the existing out-of-the-box ACLs on unrelated tables (such as Incident) were spot-checked and found unaffected, confirming the new ACL is correctly scoped to u_institution_details only.

6.7 Conclusion of Testing

All six test cases passed. The combination of a custom role, a data condition on the Branch field, and an advanced server-side script with an explicit administrator override was confirmed to correctly enforce record-level, field-value-based access control across Read, Create, Write and Delete operations.